Vulnerability Assessment & Penetration Testing

First Audit Report

For

Prologic Technologies Pvt. Ltd.

Prepared By



Imperium Solutions

401, 4th Floor, Maruti Bhavan, Ram Maruti Road, Thane (W), 400601
Web: www.imperiumsolution.com
Contact: info@imperiumsolution.com

Report Release Date	14.10.2026
Type of Audit	Android Application VAPT
Type of Audit Report	First Audit Report
Period	09.10.2026 to 14.10.2026

Document Control

Document Preparation	
Document Title	Android Application VAPT First Audit Report
Document ID	Prologic_Technologies_VAPT_First_Audit_Report_Android_Application_14_October _2026
Document Classification	Confidential
Document Version	V1.0
Prepared by	Mr. Uday Gupta
Reviewed by	Mr. Chris
Approved by	Mr. Jude Dcosta
Released by	Mr. Chris
Release date	14.10.2026

Document Change History		
Version	**Date**	**Remarks / Reason for change**
1.0	14.10.2026	First Audit Report

Document Distribution List			
Name	**Organization**	**Designation**	**Email ID**
Mandeep Saini	Prologic Technologies Pvt. Ltd.	Senior Software Engineer	mandeep@prologictechnologies.in

Table of Contents

DOCUMENT CONTROL **3**

1 INTRODUCTION **5**

1.1 Client Company Profile 5
1.2 Imperium Solutions Profile 5
1.3 Targeted Audience 5
1.4 Audit Objectives 5

2 ENGAGEMENT SCOPE **6**

2.1 Constraints / Limitations 6
2.2 Any other details 6

3 DETAILS OF THE AUDITING TEAM **7**

4 AUDIT ACTIVITIES AND TIMELINES **8**

5 AUDIT METHODOLOGY AND CRITERIA **9**

5.1 Approach and Methodology 9
5.2 Risk Rating (Severity Level Information and Description) 9
5.3 Standards 10

6 TOOLS USED **11**

7 EXECUTIVE SUMMARY **12**

7.1 Overview 12
7.2 Overall Graphical Representation of Findings 13

8 LIST OF OBSERVATIONS **14**

9 DETAILED OBSERVATIONS **19**

10 DISCLAIMER **45**

11 APPENDICES **46**

12 APPENDICES A: CERT-IN COMPLIANCE STATUS **47**

1 Introduction

1.1 Client Company Profile

Prologic Technologies is an AI-native digital product engineering and custom software development company founded in 2010. Headquartered in the Mohali/Chandigarh tech corridor in India, the firm specializes in designing, building, and scaling cloud-first digital infrastructure and custom software solutions for a global clientele. Over more than a decade, the company has evolved from a bespoke web development boutique into an advanced technology partner, helping enterprises and high-growth startups modernize legacy systems and integrate autonomous workflows.

Imperium Solutions Profile

Imperium Solutions is a Cert-IN empanelled, ISO 9001 and ISO27001 certified organization, focused on Information Security and Data Privacy domains. Established in June 2008, we aim to partner with our clients to build and implement appropriate Information Security and Data Privacy Controls.

Imperium Solutions professionals have rich domain expertise across a cross section of industry verticals and the multi-dimensional skills to meet the ever-changing business needs of our clients.

All offensive security consultants are accredited to a minimum CEH, OSCP, CISA etc registered tester or have one of the security related certifications.

1.2 Targeted Audience

Citing the identified risks and vulnerabilities as mentioned in the report, it should be considered as Strictly Confidential and accessible only to the Management, IT Manager, Software Development Team, Software Testing Team and senior staff members responsible for taking action.

1.3 Audit Objectives

1. Identify the vulnerabilities existing in the devices.
2. Create a report of the identified vulnerabilities along with POC to indicate the steps to reproduce.

2 Engagement Scope

S. No.	Asset Description	Criticality of Asset	IP Address / URL / Package Name	Location	Hash Value (in case of applications)	Version (in Case of applications)	Other details such as make and model in case of network devices or security devices.
1	Android Application	Critical	com.vedicconnect	NA	NA	NA	NA

Table 1.0 – Engagement Scope

2.1 Constraints / Limitations

1. None.

2.2 Any other details

1. None.

3 Details of the Auditing Team

S. No	Name	Designation	Email Id	Professional Qualifications / Certifications	Whether the resource has been listed in the Snapshot information published on CERT-In's website (Yes/No)
1	Mr. Uday Gupta	Information Security Consultant	support@imperiumsolution.com	CEH	No
2	Mr. Chris	Information Security Consultant	chris.f@imperiumsolution.com	CEH	Yes
3	Mr. Jude Dcosta	Project Delivery Manager Information Security	jude.dcosta@imperiumsolution.com	MSC-Cyber forensic & Information security	Yes

Table 2.0 – Details of Auditing Team

4 Audit Activities and Timelines

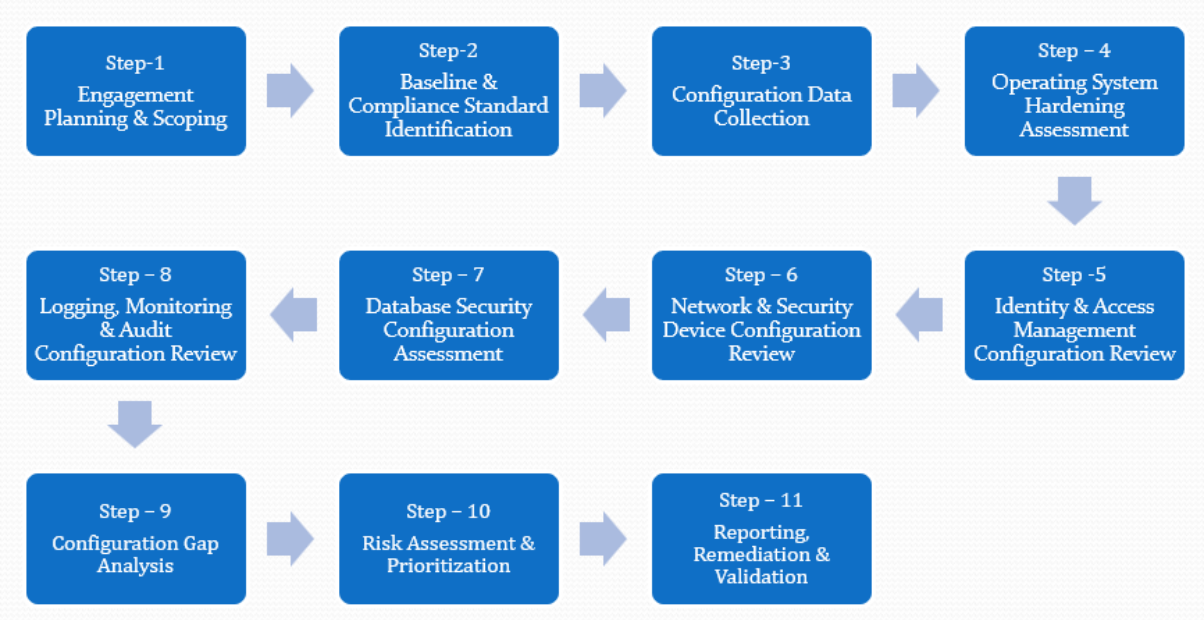
The below table illustrates the activities carried out during the assessment.

S. No.	Activity	Output	No Of Days	Period / Timeline / Date
1	Kick-off Meeting, Scope Finalization & Information Gathering	Final scope, asset details, access requirements	1	09.10.2026
2	Vulnerability Scanning	Initial scan results	2	09.10.2026 – 10.10.2026
3	Manual Verification & False Positive Removal	Validated vulnerability list	2	12.10.2026 – 13.10.2026
4	Risk Analysis, Impact Assessment & Recommendations	Risk-rated findings with remediation steps	2	13.10.2026 – 14.10.2026
5	Draft Report Preparation	Draft report	1	14.10.2026 – 14.10.2026
6	Internal Review and Approval	Reviewed and approved report	1	14.10.2026 – 14.10.2026
7	Report Submission to Client	First audit report submitted	1	14.10.2026

Table 3.0 – Audit Activities and Timelines

5 Audit Methodology and Criteria

5.1 Approach and Methodology



5.2 Risk Rating (Severity Level Information and Description)

The ratings are based on the CVSS 3.1: https://www.first.org/cvss/calculator/3.1

SEVERITY	CVSS SCORE	DESCRIPTION
Critical	**9.00 – 10.00**	Critical Business Impact - e.g., Remote Code Execution, Database Access, System Take Over. Requires fix immediately.
High	**7.00 – 8.99**	High Business Impact - e.g., Bypassing security controls, arbitrary script execution, takeover any user's account, bypass of user accounts on critical parts of the site. Requires fix as soon as possible
Medium	**4.00 – 6.99**	Typically, vulnerabilities that requires the attacker to combine it with another vulnerability to cause serious damage
Low	**0.01 – 3.99**	Can cause annoyance to the user and be used in a combination with similar vulnerabilities.
Informational	**0.0**	Bugs that do not create a threat directly or indirectly fall under this category.

Table 4.0 – Risk Rating

5.3 Standards

Following are the standards / framework used in this engagement –

- The Open Worldwide Application Security Project (OWASP)
- CERT-In Advisory
- Penetration Testing Execution Standard (PTES)
- SysAdmin, Audit, Network and Security (SANS)
- Center for Internet Security (CIS) Benchmark
- Open Source Security Testing Methodology Manual (OSSTMM3)

6 Tools Used

Sr. No.	Name of Tool / Software used	Version of the tool / software used	Open Source / Licensed
1	Burp Suite Professional	2025.5	Licensed
2	ImmuniWeb	5	Licensed

Table 5.0 – Tools Used

7 Executive Summary

7.1 Overview

Prologic Technologies Pvt. Ltd. commissioned Imperium Solutions to perform a Web Application Vulnerability Assessment Penetration Testing.

Our Information Security Assessment team would like to take this opportunity to thank all the participants for their assistance and co-operation in ensuring that the assessment could be completed smoothly and in a timely manner.

During the initial assessment, the Website was found to contain a total of 10 vulnerabilities.

The assessment was conducted by manual validation to minimize the possibility of false positives. It is recommended that all identified vulnerabilities be remediated in a timely manner to further strengthen the overall security posture of the application.

It is further recommended that the application to be scanned for vulnerabilities whenever there is a change in the configuration or at least once in a year, whichever is earlier. All changes to the application should be done through a proper change management process.

Note: As the scope of this engagement was limited to a technical security assessment of the application / infrastructure, the audit focused on identifying and validating security vulnerabilities, misconfigurations, and technical risks within the agreed scope.

Accordingly, the report provides a detailed summary of the technical findings, their potential security impact, and recommended remediation measures. However, assessment of organization-specific business risks, operational impacts, financial implications, and overall enterprise risk exposure was outside the scope of this audit. Therefore, a comprehensive business risk evaluation and security posture assessment from a business perspective have not been included in this report.

7.2 Overall Graphical Representation of Findings

Status	Count
Critical	03
High	03
Medium	04
Low	00
Info	00
Total	**10**

Table 6.0 – Vulnerability Count

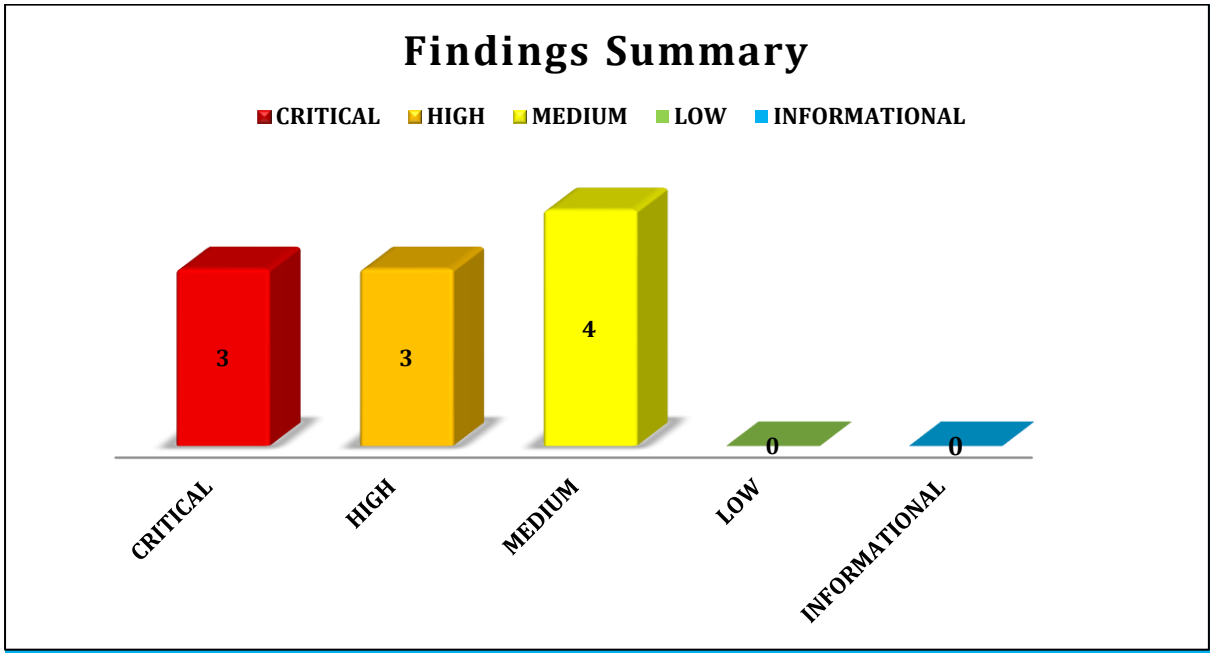


Figure 1.0 – Vulnerability Summary Graph

8 List Of Observations

S. No.	Vulnerability Name	Affected Asset / URL	CWE / CVE	Severity	Recommendation	Reference	Status
1.	Client-Side OTP Validation Bypass Leading to Account Takeover	/api/verifyEmailOTP, /api/ResetPassword	CWE-602, CWE-287, CWE-640	Critical	Enforce OTP validation entirely on the server before authorizing any password-reset operation. Never rely on client-side response parameters, such as success, or HTTP status codes as proof of successful authentication.	OWASP — Forgot Password Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html CWE-602 — Client-Side Enforcement of Server-Side Security: https://cwe.mitre.org/data/definitions/602.html	New
2.	Broken Access Control (IDOR) – Unauthorized Access to Sensitive User Information	/api/getUserDetails?userId=	CWE-639, CWE-862, CWE-359	Critical	Enforce server-side authorization checks for every request to ensure users can access only records they are explicitly permitted to view. Derive the authenticated user's identity from the validated server-side session or access token rather than trusting the client-supplied userId.	OWASP — Insecure Direct Object Reference Prevention: https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html CWE-639 — Authorization Bypass Through User-Controlled	New

S. No.	Vulnerability Name	Affected Asset / URL	CWE / CVE	Severity	Recommendation	Reference	Status
						Key: https://cwe.mitre.org/data/definitions/639.html	
3.	Client-Side Price Manipulation Leading to Unauthorized Appointment Fee Reduction	GET /api/getDiscountedValue?userId=MTE2MA%3D%3D&Promocode=TEST10&AppointmentFee=300	CWE-602, CWE-472, CWE-840	Critical	Calculate the final appointment fee and validate promo codes exclusively on the server side. Never trust client-side response data or UI-displayed prices as authoritative payment amounts.	OWASP Business Logic Security Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Business_Logic_Security_Cheat_Sheet.html CWE-602 — Client-Side Enforcement of Server-Side Security: https://cwe.mitre.org/data/definitions/602.html	New
4.	Email OTP Verification Bypass During Account Registration	/api/verifyEmailOTP	CWE-602, CWE-287, CWE-345	High	Perform email OTP validation on the server before marking an email address as verified or completing registration. Never rely on client-side response manipulation or a client-controlled success indicator as	OWASP Authentication Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html	New

S. No.	Vulnerability Name	Affected Asset / URL	CWE / CVE	Severity	Recommendation	Reference	Status
					proof of successful verification.	CWE-602 — Client-Side Enforcement of Server-Side Security: https://cwe.mitre.org/data/definitions/602.html	
5.	Outdated PHP Version Disclosure	staging.ayurverse.health	CWE-1104, CWE-200	High	Upgrade PHP 8.3.14 to the latest patched release compatible with the application, or migrate to a newer supported PHP branch after compatibility testing. Review official PHP security advisories and changelogs to identify and remediate vulnerabilities applicable to the installed runtime and enabled extensions.	PHP Supported Versions: https://www.php.net/supported-versions.php PHP Official Changelog: https://www.php.net/ChangeLog-8.php	
6.	Hardcoded Sensitive Data	res/values/strings.xml	CWE-798	High	Remove sensitive credentials, API keys, passwords, and cryptographic secrets from the application source code. Retrieve secrets securely from a backend service or an appropriate secrets-management solution.	MITRE CWE-798 – Use of Hard-coded Credentials: https://cwe.mitre.org/data/definitions/798.html OWASP MASWE – Hardcoded API Keys: https://mas.o	New

S. No.	Vulnerability Name	Affected Asset / URL	CWE / CVE	Severity	Recommendation	Reference	Status
						wasp.org/MASWE/	
7.	External Data Storage	Com/rnfs/RNFSManager.java, C/d.java, M6/p.java, Z0/f.java, Z0/r.java, com/ReactNativeBlobUtil/ReactNativeBlobUtil.java, com/htmltopdf/HtmlToPdfModule.java, com/rnfs/RNFSManager.java, iio/invertase/firebase/utils/ReactNativeFirebaseUtilsModule.java, f1/C0525b.java, o1/C0971a.java	CWE-922	Medium	Avoid storing sensitive application data in shared external storage. confidential information in application-specific internal storage with appropriate access restrictions.	OWASP MASVS – Storage: https://mas.owasp.org/MASVS/05-MASVS-STORAGE/ Android Developers – App-specific storage: https://developer.android.com/training/data-storage/app-specific	
8.	Weak Encryption Algorithms	N2/AbstractC0939b.java	CWE-327	Medium	Replace weak or deprecated encryption algorithms with industry-standard algorithms such as AES-128 or AES-256 using secure modes of operation. Avoid insecure algorithms and modes such as DES, 3DES where deprecated, RC4, and ECB mode.	Cryptographic Storage Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html MITRE CWE-327 – Use of a Broken or Risky Cryptographic Algorithm: https://cwe.mitre.org/dat	

S. No.	Vulnerability Name	Affected Asset / URL	CWE / CVE	Severity	Recommendation	Reference	Status
						a/definitions /327.html	
9.	Weak Hashing Algorithms	C1/AbstractC0264a.java, P7/k.java	CWE-327	Medium	Replace weak or deprecated hashing algorithms with modern, cryptographically secure algorithms. For password storage, use dedicated password hashing algorithms such as Argon2id, bcrypt, or scrypt.	OWASP Password Storage Cheat Sheet MITRE CWE-327 – Use of a Broken or Risky Cryptographic Algorithm NIST SP 800-63B – Digital Identity Guidelines	New
10	JS Enabled in a WebView	B/RunnableC0249d.java, com/razorpay/MagicXActivity.java	CWE-79, CWE-749	Medium	Disable JavaScript execution in WebViews where it is not required for application functionality. If JavaScript is necessary, restrict WebView content to trusted and controlled sources.	https://developer.android.com/privacy-and-security/security-tips#webview https://developer.android.com/reference/android/webkit/WebView.html	New

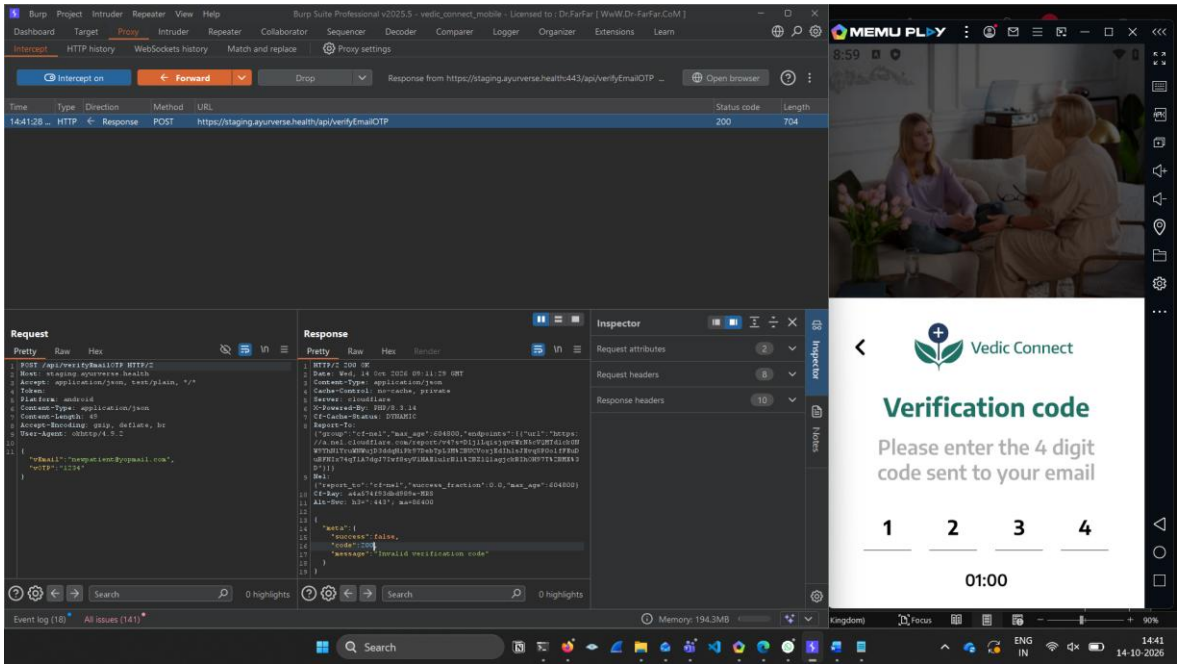
Table 7.0 – List of Observations

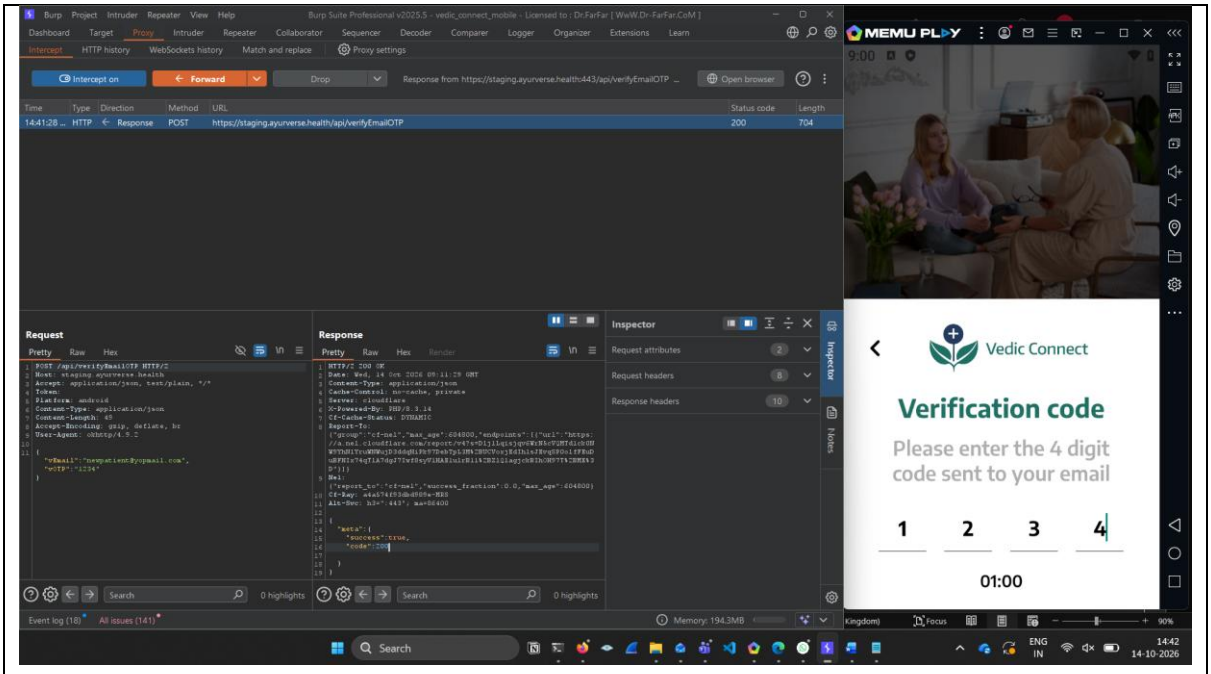
9 Detailed Observations

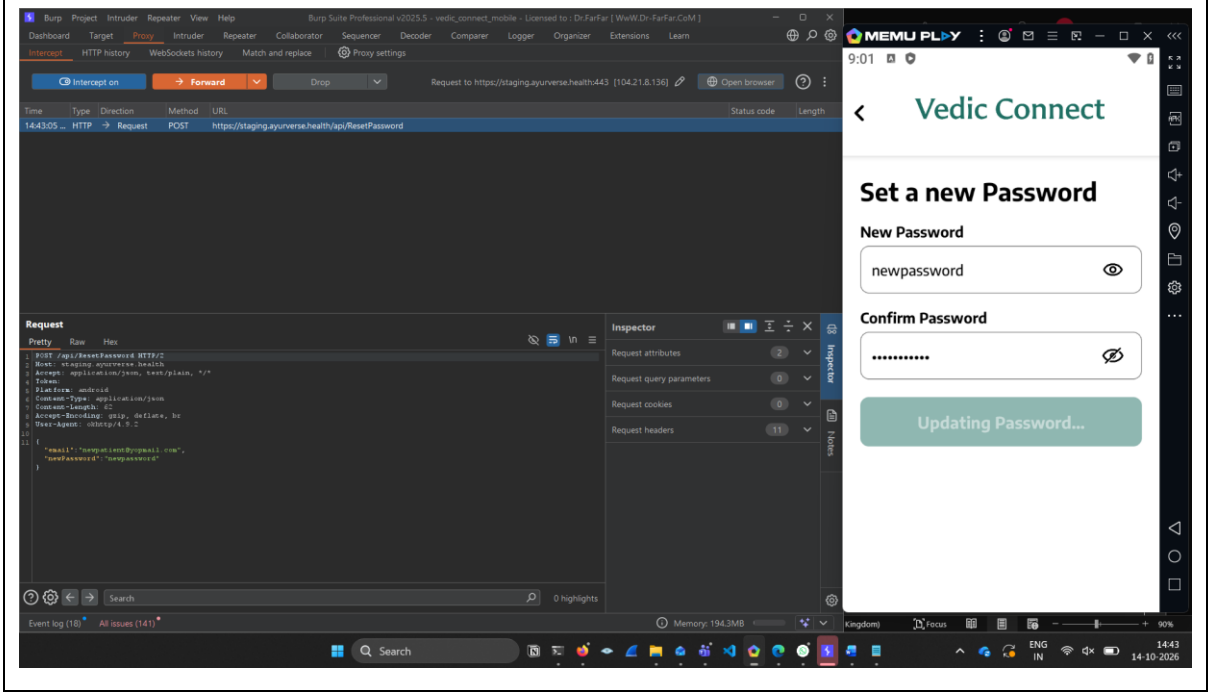
Vulnerability 1

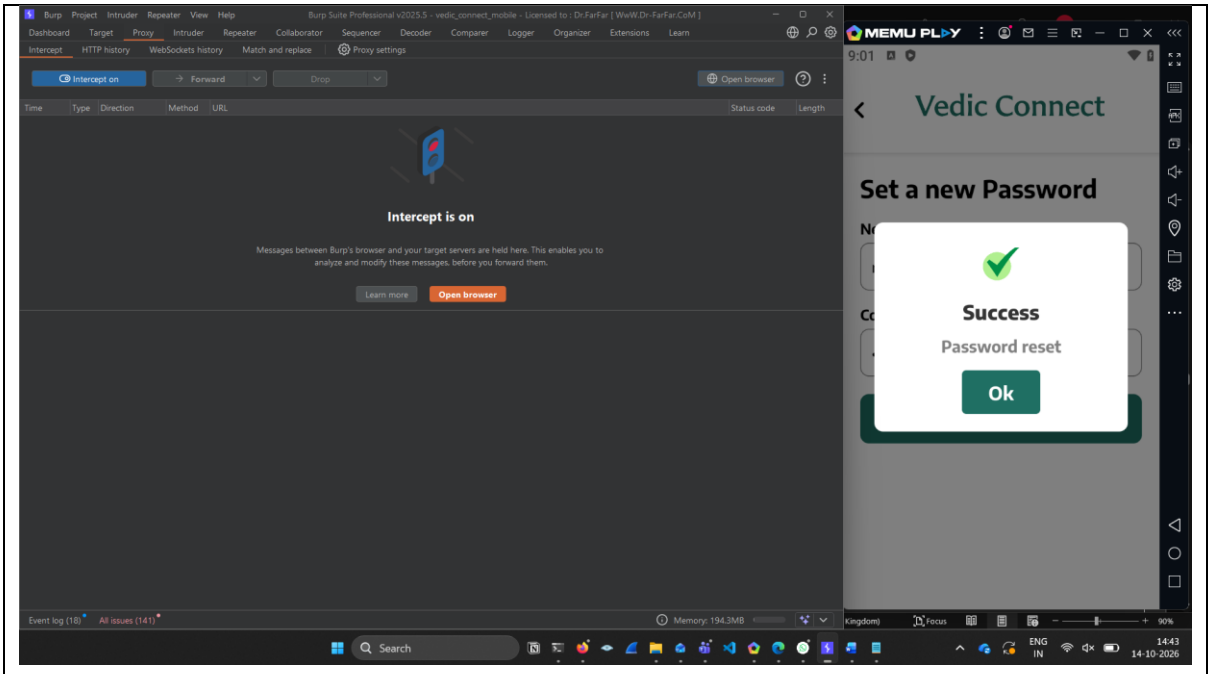
Vulnerability Name	Client-Side OTP Validation Bypass Leading to Account Takeover
Affected Asset i.e. IP / URL / Application etc.	/api/verifyEmailOTP, /api/ResetPassword
Detailed observation / Vulnerable point	During testing of the application's forgot-password functionality, an arbitrary user's email address was entered to initiate the password reset process. At the OTP verification stage, an invalid OTP (1234) was submitted, and the corresponding server response was intercepted and modified using Burp Suite by changing the HTTP status code to 200 and the response parameter success to true. The application accepted the modified response and allowed the password-reset workflow to proceed without successful OTP verification. This indicates that the application relies on client-side response handling without adequately enforcing OTP verification on the server side. Additionally, a separate Broken Access Control vulnerability was identified in which modifying the user ID in GET requests allowed access to other users' information and data.
Impact	An attacker may bypass the OTP verification step in the password-reset process and potentially reset another user's password, resulting in account takeover. Successful exploitation could allow unauthorized access to sensitive account information and user-specific functionality. When combined with the separately identified Broken Access Control vulnerability, an attacker may also be able to access other users' data. The overall impact depends on whether the backend permits the password reset and subsequent authentication without independently validating the OTP.
CVE/CWE	CWE-602: Client-Side Enforcement of Server-Side Security. CWE-287: Improper Authentication. CWE-640: Weak Password Recovery Mechanism for Forgotten Password.
Severity	**Critical**
Recommendation	• Enforce OTP validation entirely on the server before authorizing any password-reset operation. • Never rely on client-side response parameters, such as success, or HTTP status codes as proof of successful authentication. • Bind OTP verification to the relevant user account and password-reset transaction. • Implement OTP expiration, single-use enforcement, attempt limits, and rate limiting.

	• Issue a short-lived, securely generated password-reset token only after successful server-side OTP verification. • Invalidate outstanding reset tokens and relevant sessions as appropriate after a successful password change. • Perform negative testing to ensure that invalid OTPs, modified responses, and direct requests cannot bypass verification.
Reference	OWASP — Forgot Password Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html CWE-602 — Client-Side Enforcement of Server-Side Security: https://cwe.mitre.org/data/definitions/602.html CWE-287 — Improper Authentication: https://cwe.mitre.org/data/definitions/287.html CWE-640 — Weak Password Recovery Mechanism for Forgotten Password: https://cwe.mitre.org/data/definitions/640.html OWASP — Authentication Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
New or Repeat observation	New
Status	New
References to evidences / Proof of Concept	




Vedic Connect
Verification code
Please enter the 4 digit code sent to your email
1 2 3 4
01:00


Vedic Connect
Set a new Password
New Password
newpassword
Confirm Password
Updating Password...



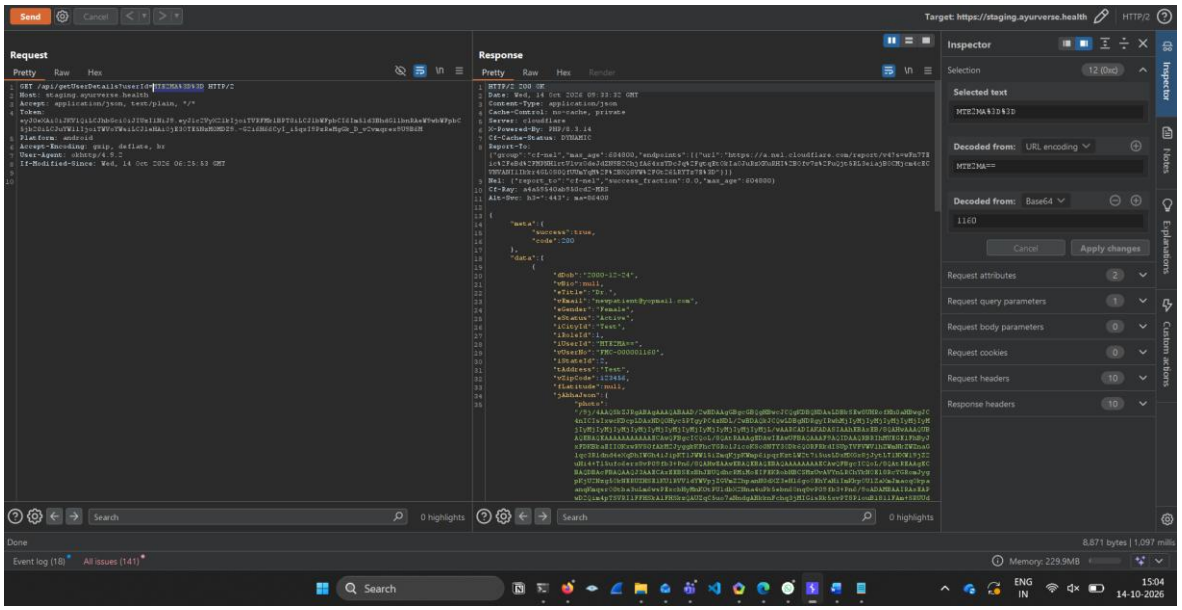
Closure Proof of Concept

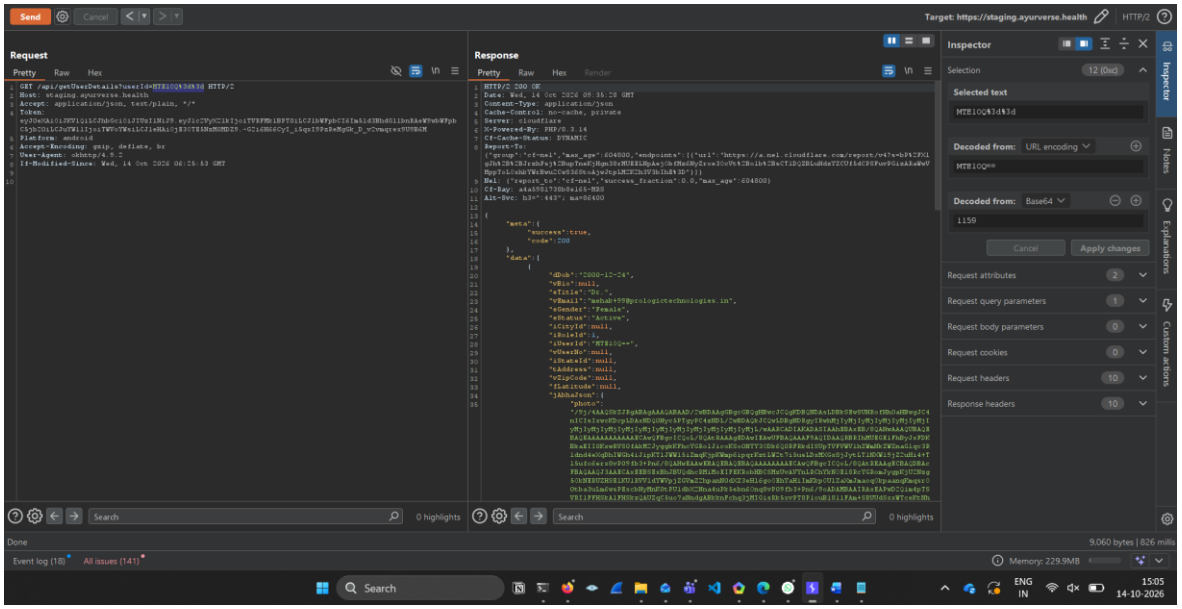
NA

Vulnerability 2

Vulnerability Name	Broken Access Control (IDOR) – Unauthorized Access to Sensitive User Information
Affected Asset i.e. IP / URL / Application etc.	/api/getUserDetails?userId=
Detailed observation / Vulnerable point	Upon logging into the application, a GET request to /api/getUserDetails?userId=MTE2MA%3D%3D was observed. The userId parameter contains a Base64-encoded identifier, which decodes to 1160. By replacing this value with another user's identifier, such as 1159 encoded in Base64, the application returned the corresponding user's information without enforcing proper server-side authorization. The exposed information included mobile numbers, ABHA addresses, ABHA numbers, access tokens, device tokens, and bcrypt password hashes. Base64 encoding provides no security protection, and the application fails to verify that the authenticated user is authorized to access the requested user's records.
Impact	An attacker with a valid application account could potentially enumerate user identifiers and access other users' sensitive personal and health-related information. Exposure of access tokens and device tokens may enable unauthorized access to user accounts or associated services, depending on token validity and scope. Disclosure of bcrypt password hashes could facilitate offline password-cracking attempts, while exposure of ABHA identifiers and mobile numbers increases the risk of privacy violations, identity misuse, and targeted attacks. This vulnerability presents a significant risk to the confidentiality of user data.
CVE/CWE	CWE-639: Authorization Bypass Through User-Controlled Key. CWE-862: Missing Authorization. CWE-359: Exposure of Private Personal Information to an Unauthorized Actor
Severity	**Critical**
Recommendation	• Enforce server-side authorization checks for every request to ensure users can access only records they are explicitly permitted to view. • Derive the authenticated user's identity from the validated server-side session or access token rather than trusting the client-supplied userId. • Apply role-based or attribute-based access control for legitimate administrative and support functions.

	• Avoid returning sensitive fields such as password hashes, access tokens, and device tokens in general user-detail API responses. • Rotate or revoke any exposed tokens where they may be valid, and assess whether unauthorized use occurred. • Review API endpoints for similar insecure direct object references and implement automated authorization tests. • Apply rate limiting and monitoring to detect systematic user-ID enumeration. • Treat Base64 encoding as a data representation mechanism, not an authorization or security control.
Reference	OWASP — Insecure Direct Object Reference Prevention: https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html CWE-639 — Authorization Bypass Through User-Controlled Key: https://cwe.mitre.org/data/definitions/639.html CWE-862 — Missing Authorization: https://cwe.mitre.org/data/definitions/862.html CWE-359 — Exposure of Private Personal Information to an Unauthorized Actor: https://cwe.mitre.org/data/definitions/359.html OWASP API Security — Broken Object Level Authorization: https://owasp.org/API-Security/editions/2023/en/0xa1-broken-object-level-authorization/
New or Repeat observation	New
Status	New
References to evidences / Proof of Concept	





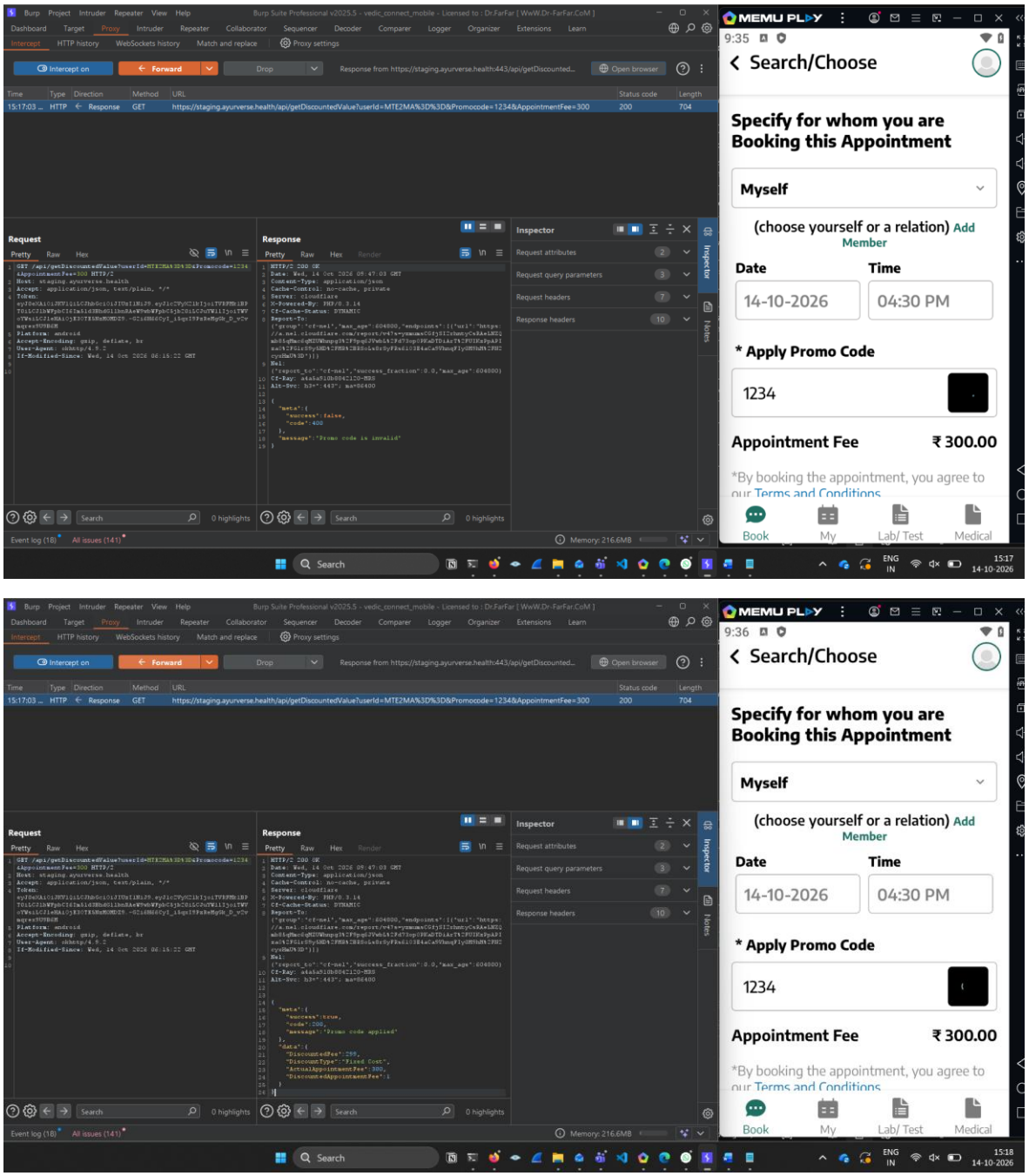
Closure Proof of Concept

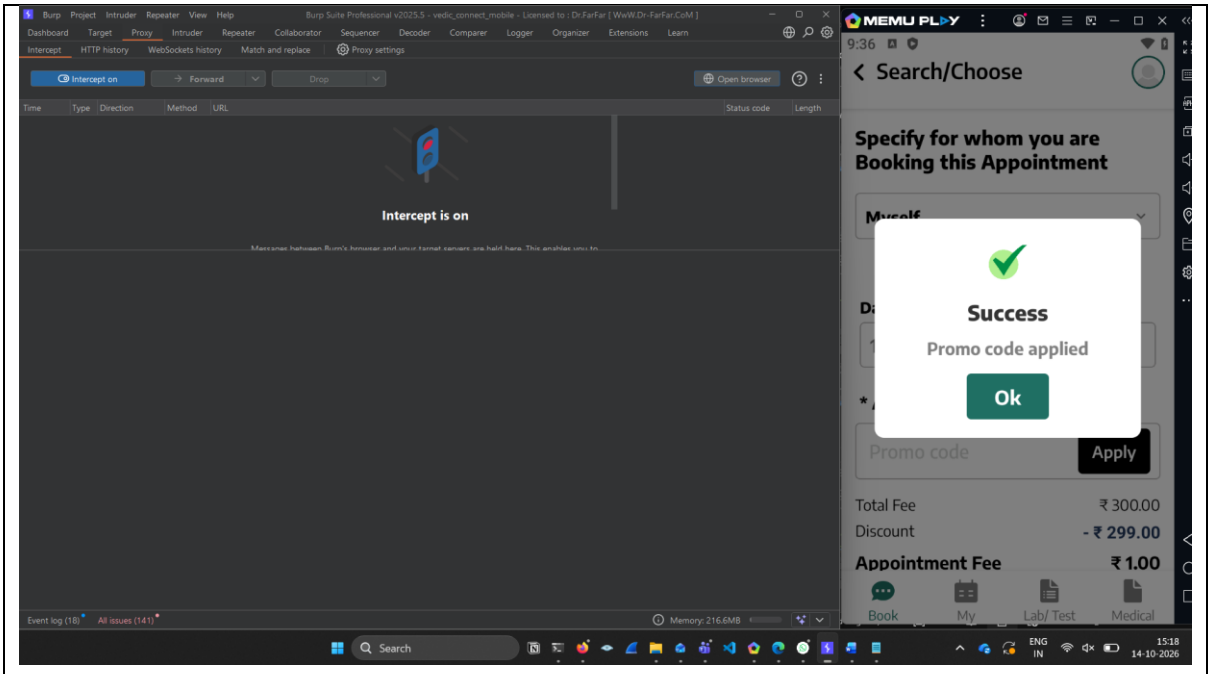
NA

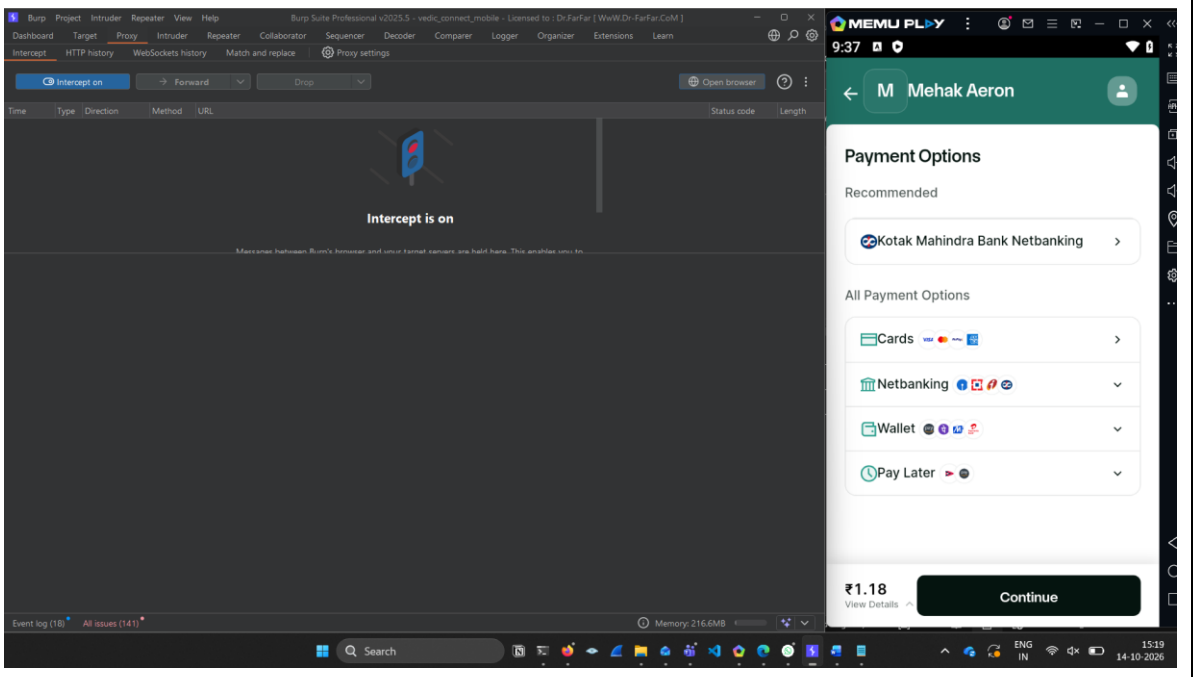
Vulnerability 3

Vulnerability Name	Client-Side Price Manipulation Leading to Unauthorized Appointment Fee Reduction
Affected Asset i.e. IP / URL / Application etc.	GET /api/getDiscountedValue?userId=MTE2MA%3D%3D&Promocode=TEST10&AppointmentFee=300
Detailed observation / Vulnerable point	During testing of the doctor appointment booking functionality, a GET request to /api/getDiscountedValue?userId=MTE2MA%3D%3D&Promocode=1234&AppointmentFee=300 was observed when submitting a promo code. Upon entering an invalid promo code, the application returned an error response indicating that the promo code was invalid. By intercepting the response using Burp Suite and modifying the response body to indicate successful promo code application, with the DiscountedAppointmentFee set to ₹1 instead of the original appointment fee of ₹300, the application displayed the manipulated amount throughout the checkout process, including the Razorpay payment gateway. This indicates that the client-side application may be trusting the modified API response when determining the appointment fee, without adequately validating the discount and payable amount on the server side.
Impact	An attacker may manipulate the displayed appointment fee and potentially pay a substantially reduced amount for medical appointments without a valid promotional discount. If the backend also accepts the manipulated amount when creating or verifying the payment transaction, this could result in financial losses to the organization and unauthorized use of paid services. The actual financial impact depends on whether the server-side payment verification process independently enforces the correct appointment fee.
CVE/CWE	CWE-602: Client-Side Enforcement of Server-Side Security. CWE-472: External Control of Assumed-Immutable Web Parameter. CWE-840: Business Logic Errors.
Severity	**Critical**
Recommendation	• Calculate the final appointment fee and validate promo codes exclusively on the server side. • Never trust client-side response data or UI-displayed prices as authoritative payment amounts. • Generate Razorpay payment orders using the verified appointment fee calculated by the backend.

	• Verify the payment order amount, currency, transaction status, and appointment details on the server before confirming the booking. • Reject invalid, expired, ineligible, or tampered discount values and enforce applicable discount limits. • Ensure that payment verification and appointment confirmation are bound to the same server-generated order and transaction. • Perform negative testing to confirm that response tampering cannot result in an underpriced payment being accepted.
Reference	OWASP Business Logic Security Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Business_Logic_Security_Cheat_Sheet.html CWE-602 — Client-Side Enforcement of Server-Side Security: https://cwe.mitre.org/data/definitions/602.html CWE-472 — External Control of Assumed-Immutable Web Parameter: https://cwe.mitre.org/data/definitions/472.html Razorpay — Orders API: https://razorpay.com/docs/api/orders/ Razorpay — Payment Signature Verification: https://razorpay.com/docs/payments/server-integration/standard/integration-steps/#verify-payment-signature
New or Repeat observation	New
Status	New
References to evidences / Proof of Concept	


Search/Choose
Specify for whom you are Booking this Appointment
Myself
(choose yourself or a relation) Add Member
Date
Time
14-10-2026
04:30 PM
* Apply Promo Code
1234
Appointment Fee
₹ 300.00
*By booking the appointment, you agree to our Terms and Conditions
Book
My
Lab/ Test
Medical
Search/Choose
Specify for whom you are Booking this Appointment
Myself
(choose yourself or a relation) Add Member
Date
Time
14-10-2026
04:30 PM
* Apply Promo Code
1234
Appointment Fee
₹ 300.00
*By booking the appointment, you agree to our Terms and Conditions
Book
My
Lab/ Test
Medical





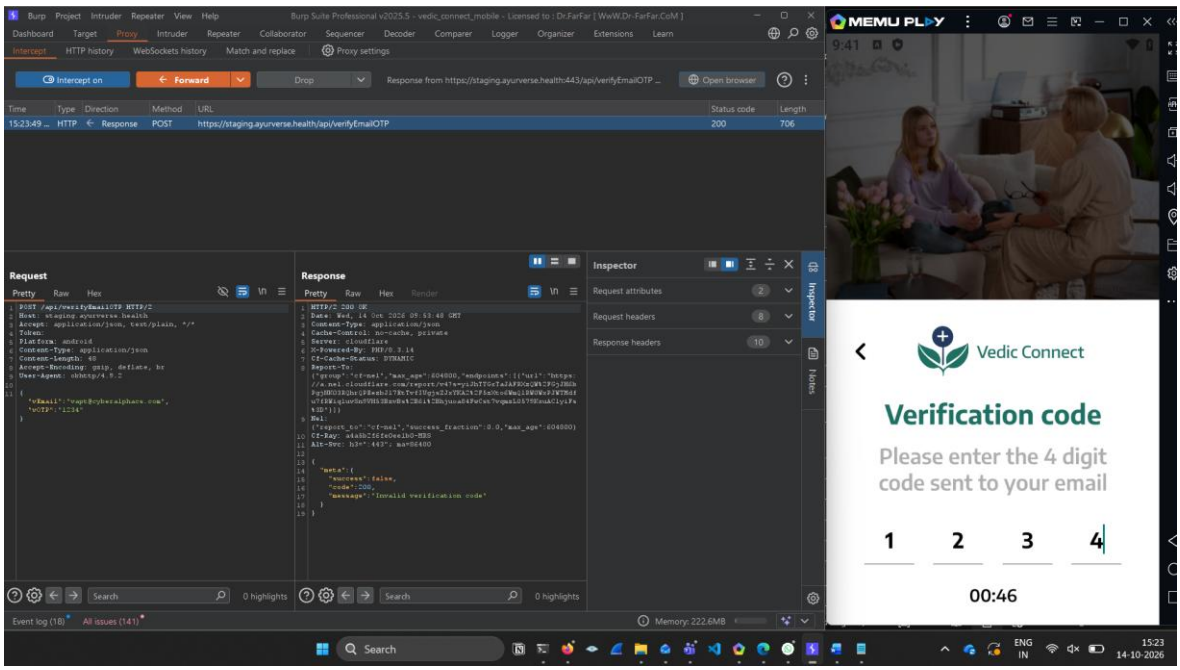
Closure Proof of Concept

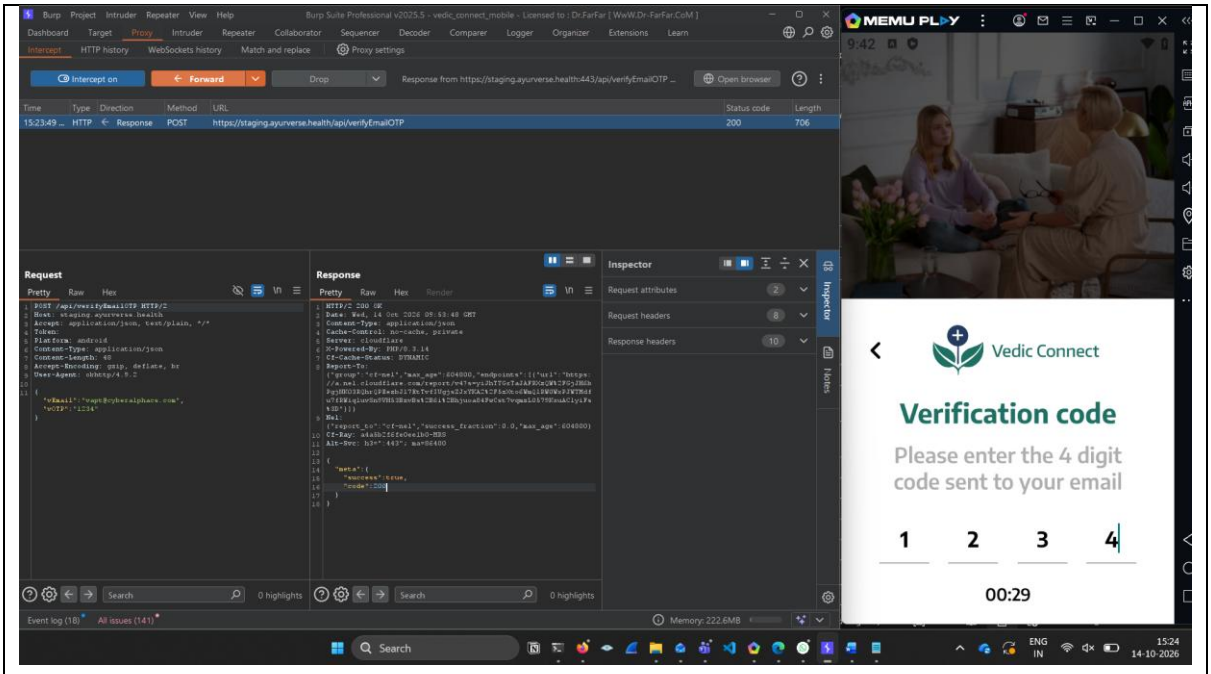
NA

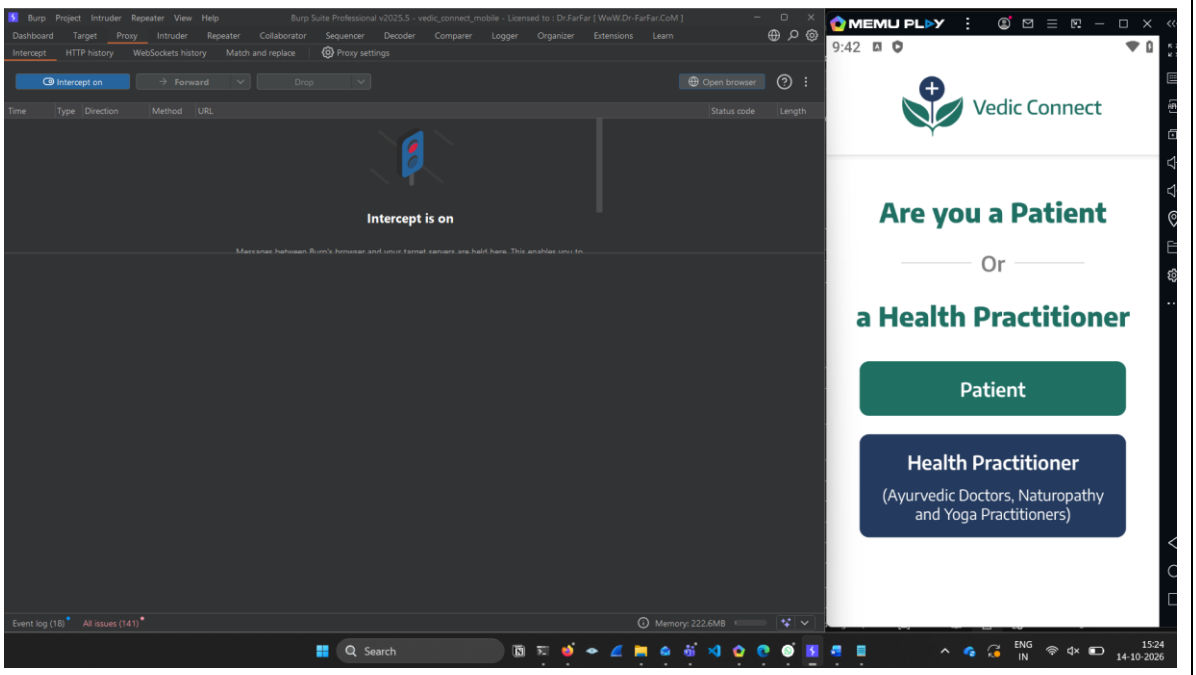
Vulnerability 4

Vulnerability Name	Email OTP Verification Bypass During Account Registration
Affected Asset i.e. IP / URL / Application etc.	/api/verifyEmailOTP
Detailed observation / Vulnerable point	During testing of the account registration functionality, the application was observed sending a POST request to /api/verifyEmailOTP to verify the email OTP entered by the user. By submitting an incorrect OTP and intercepting the server response using Burp Suite, the response parameter "success": false was modified to "success": true. The application subsequently allowed account registration to proceed without successfully validating the email OTP. This indicates that the client-side application relies on the response status to determine verification success without adequately enforcing the email OTP verification on the server side.
Impact	An attacker may bypass email verification and register accounts using email addresses without proving ownership of the corresponding email accounts. This could facilitate fraudulent registrations, misuse of application functionality, and circumvention of controls intended to ensure valid email ownership. The severity depends on whether the backend independently enforces email verification before account activation and access to protected functionality.
CVE/CWE	CWE-602: Client-Side Enforcement of Server-Side Security. CWE-287: Improper Authentication. CWE-345: Insufficient Verification of Data Authenticity.
Severity	**High**
Recommendation	• Perform email OTP validation on the server before marking an email address as verified or completing registration. • Never rely on client-side response manipulation or a client-controlled success indicator as proof of successful verification. • Bind each OTP to the intended email address and registration transaction. • Implement OTP expiration, single-use enforcement, and rate limiting for verification attempts. • Prevent unverified accounts from accessing protected functionality until email ownership has been confirmed. • Add server-side validation and negative tests to ensure incorrect, expired, reused, or missing OTPs are rejected.

Reference	OWASP Authentication Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html CWE-602 — Client-Side Enforcement of Server-Side Security: https://cwe.mitre.org/data/definitions/602.html CWE-287 — Improper Authentication: https://cwe.mitre.org/data/definitions/287.html CWE-345 — Insufficient Verification of Data Authenticity: https://cwe.mitre.org/data/definitions/345.html OWASP Input Validation Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
New or Repeat observation	New
Status	New
References to evidences / Proof of Concept	





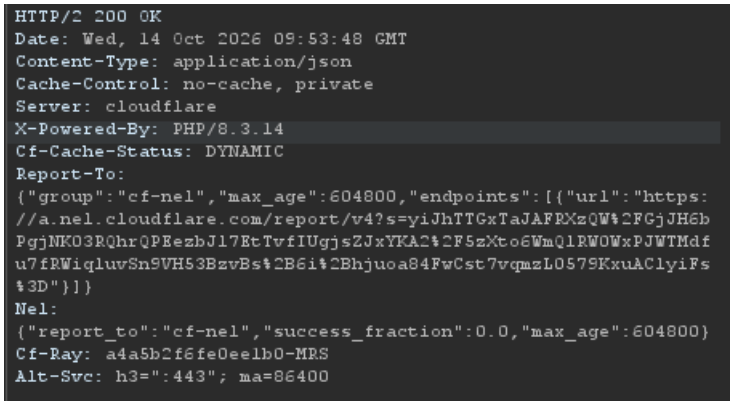


Closure Proof of Concept

NA

Vulnerability 5

Vulnerability Name	Outdated PHP Version Disclosure
Affected Asset i.e. IP / URL / Application etc.	staging.ayurverse.health
Detailed observation / Vulnerable point	During testing, the HTTP response headers were observed disclosing the backend PHP version through the X-Powered-By header, which returned PHP/8.3.14. This indicates that the application is running PHP version 8.3.14, an older release for which subsequent updates have introduced additional security fixes. As of the assessment date, PHP 8.3.35 has been released, and the official PHP changelog documents security fixes introduced after version 8.3.14. Running an outdated runtime may leave the application exposed to known vulnerabilities, depending on the installed extensions, configuration, and affected code paths
Impact	Running an outdated PHP version may expose the application to known security vulnerabilities that could potentially result in information disclosure, denial of service, or other security impacts, depending on the affected components and exploitability. Additionally, disclosing the runtime version provides attackers with information that may help identify version-specific attack vectors. Actual exploitability has not been established through the version header alone.
CVE/CWE	CWE-1104: Use of Unmaintained Third Party Components — not directly applicable, as PHP 8.3 remains within its official security-support lifecycle. CWE-200: Exposure of Sensitive Information to an Unauthorized Actor — potentially relevant to unnecessary technology-version disclosure.
Severity	**High**
Recommendation	• Upgrade PHP 8.3.14 to the latest patched release compatible with the application, or migrate to a newer supported PHP branch after compatibility testing. • Review official PHP security advisories and changelogs to identify and remediate vulnerabilities applicable to the installed runtime and enabled extensions. • Disable unnecessary version disclosure by removing the X-Powered-By header from HTTP responses. • Establish a regular patch-management process to ensure the runtime and its dependencies receive timely security updates. • Perform regression testing after upgrading to verify application compatibility and functionality.

Reference	PHP Supported Versions: https://www.php.net/supported-versions.php PHP Official Changelog: https://www.php.net/ChangeLog-8.php PHP 8.3.14 Release Announcement: https://www.php.net/releases/8_3_14.php CWE-200 — Exposure of Sensitive Information to an Unauthorized Actor: https://cwe.mitre.org/data/definitions/200.html CWE-1104 — Use of Unmaintained Third Party Components: https://cwe.mitre.org/data/definitions/1104.html
New or Repeat observation	New
Status	New
References to evidences / Proof of Concept	
	
Closure Proof of Concept	
NA	

Vulnerability 6

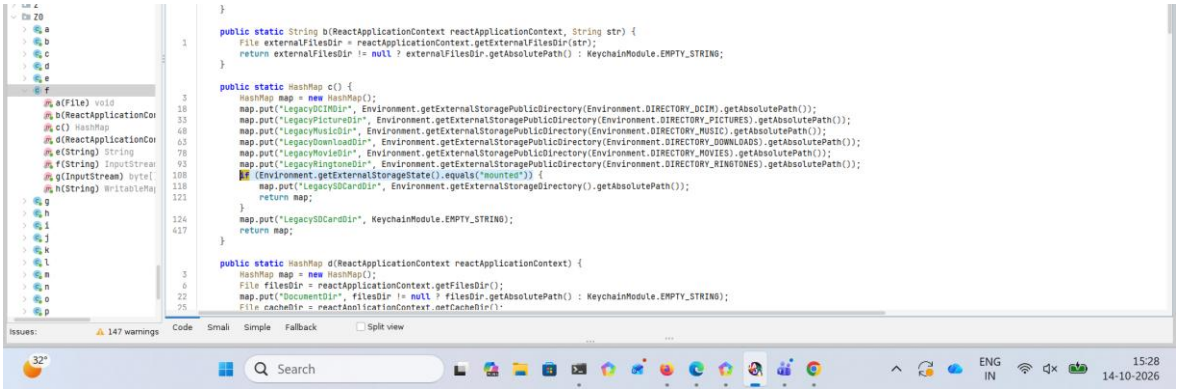
Vulnerability Name	Hardcoded Sensitive Data
Affected Asset i.e. IP / URL / Application etc.	res/values/strings.xml
Detailed observation / Vulnerable point	The mobile application contains potentially sensitive hardcoded data. An attacker with an access to the mobile application can easily extract this data from the application and use it in any further attacks.
Impact	Exposure of hardcoded sensitive information may lead to unauthorized access to application resources, API abuse, data leakage, or compromise of backend systems. If the exposed information includes credentials, API keys, or cryptographic secrets, attackers may misuse them to impersonate the application or access restricted services.
CVE/CWE	CWE-798 – Use of Hard-coded Credentials
Severity	High
Recommendation	• Remove sensitive credentials, API keys, passwords, and cryptographic secrets from the application source code. • Retrieve secrets securely from a backend service or an appropriate secrets-management solution. • Implement server-side authorization and never rely on client-side secrets as the sole security control. • Revoke and rotate any exposed credentials or keys. • Review the compiled application package for hardcoded secrets using static analysis tools. • Apply least-privilege access controls and monitor the usage of exposed API keys or credentials.
Reference	MITRE CWE-798 – Use of Hard-coded Credentials: https://cwe.mitre.org/data/definitions/798.html OWASP MASWE – Hardcoded API Keys: https://mas.owasp.org/MASWE/ OWASP Mobile Application Security Testing Guide (MASTG): https://mas.owasp.org/MASTG/
New or Repeat observation	New
Status	New
References to evidences / Proof of Concept	



Closure Proof of Concept
NA

Vulnerability 7

Vulnerability Name	External Data Storage
Affected Asset i.e. IP / URL / Application etc.	Com/rnfs/RNFSManager.java, C/d.java, M6/p.java, Z0/f.java, Z0/r.java, com/ReactNativeBlobUtil/ReactNativeBlobUtil.java, com/htmltopdf/HtmlToPdfModule.java, com/rnfs/RNFSManager.java, iio/invertase/firebase/utils/ReactNativeFirebaseUtilsModule.java, f1/C0525b.java, o1/C0971a.java
Detailed observation / Vulnerable point	The mobile application can access external storage (e.g. SD card) in read or write mode. Application data stored on external data storage may be accessed by other applications (including malicious ones) under certain conditions and bring risks of data theft, corruption or tampering.
Impact	An attacker may exploit insecure external storage practices to access sensitive information, modify application files, or tamper with stored data. This could result in data leakage, data integrity compromise, and potential exposure of credentials or other confidential information, depending on the type of data stored and the device's security configuration.
CVE/CWE	CWE-922 – Insecure Storage of Sensitive Information
Severity	**Medium**
Recommendation	• Avoid storing sensitive application data in shared external storage. • Store confidential information in application-specific internal storage with appropriate access restrictions. • Encrypt sensitive data at rest when external storage is unavoidable. • Validate the integrity of files read from external storage before processing them. • Apply strict file permissions and avoid exposing sensitive files to other applications. • Review the application for unintended storage of credentials, tokens, personal information, and other sensitive data.
Reference	OWASP MASVS – Storage: https://mas.owasp.org/MASVS/05-MASVS-STORAGE/ Android Developers – App-specific storage: https://developer.android.com/training/data-storage/app-specific MITRE CWE-922 – Insecure Storage of Sensitive Information: https://cwe.mitre.org/data/definitions/922.html
New or Repeat observation	New
Status	New

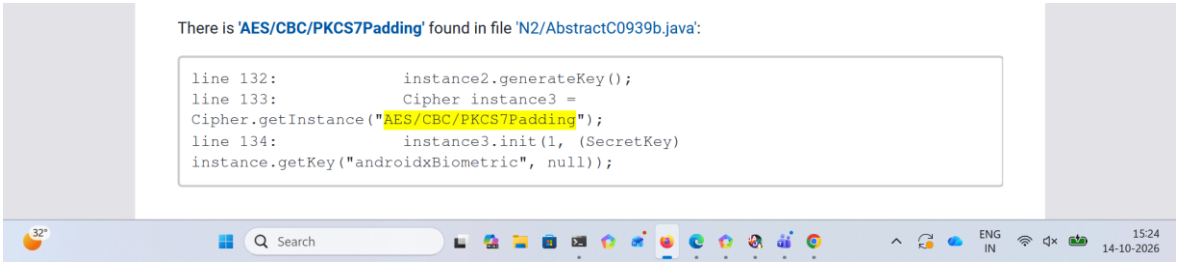
References to evidences / Proof of Concept

Closure Proof of Concept
NA

Vulnerability 8

Vulnerability Name	Weak Encryption Algorithms
Affected Asset i.e. IP / URL / Application etc.	N2/AbstractC0939b.java
Detailed observation / Vulnerable point	During the assessment, it was observed that the application uses weak or outdated encryption algorithms that may not provide adequate protection for sensitive information. The use of deprecated cryptographic algorithms or insecure encryption configurations can weaken data confidentiality and expose information to cryptographic attacks.
Impact	An attacker may exploit weaknesses in the encryption algorithm to decrypt sensitive information, potentially exposing credentials, personal data, or other confidential application information. The severity of the impact depends on the algorithm used, the encryption configuration, and the sensitivity of the protected data.
CVE/CWE	CWE-327 – Use of a Broken or Risky Cryptographic Algorithm
Severity	**Medium**
Recommendation	• Replace weak or deprecated encryption algorithms with industry-standard algorithms such as AES-128 or AES-256 using secure modes of operation. • Avoid insecure algorithms and modes such as DES, 3DES where deprecated, RC4, and ECB mode. • Use authenticated encryption, such as AES-GCM, wherever applicable. • Ensure cryptographic keys are securely generated, stored, rotated, and managed. • Review the application's cryptographic implementation and update insecure configurations in accordance with current security standards.
Reference	Cryptographic Storage Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Cryptographic_Storage_Cheat_Sheet.html MITRE CWE-327 – Use of a Broken or Risky Cryptographic Algorithm: https://cwe.mitre.org/data/definitions/327.html NIST SP 800-57 – Recommendation for Key Management: https://csrc.nist.gov/pubs/sp/800/57/pt1/r5/final
New or Repeat observation	New

Status	New

References to evidences / Proof of Concept

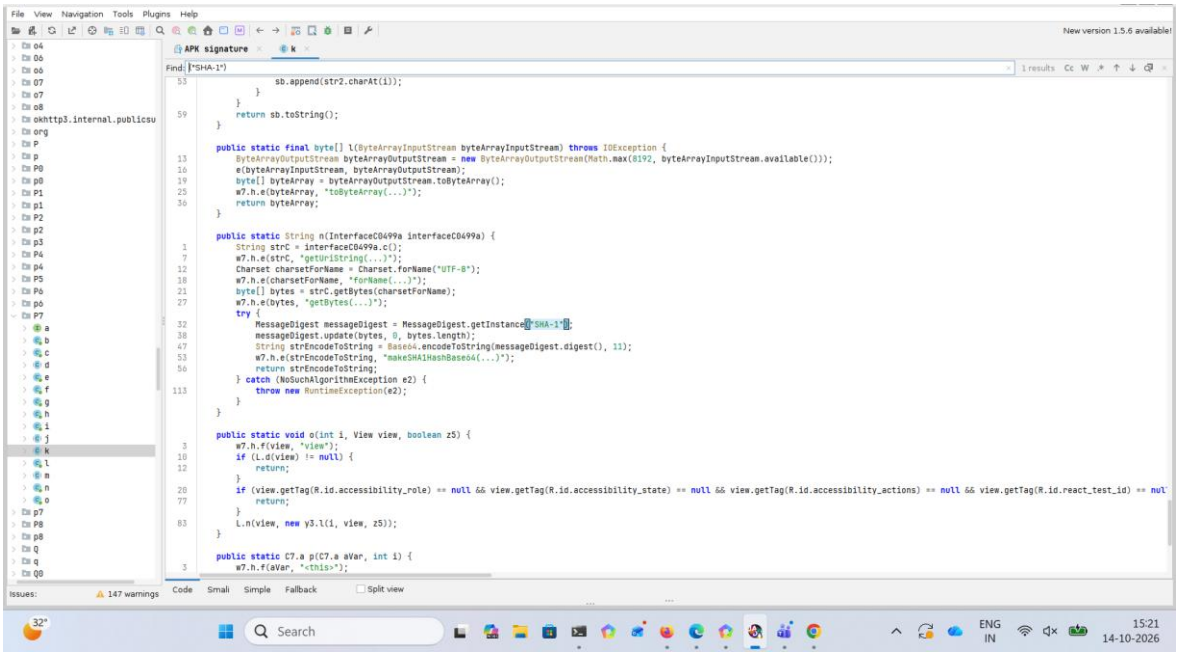


Closure Proof of Concept

NA

Vulnerability 9

Vulnerability Name	Weak Hashing Algorithms
Affected Asset i.e. IP / URL / Application etc.	C1/AbstractC0264a.java, P7/k.java
Detailed observation / Vulnerable point	The mobile application uses weak hashing algorithms. Weak hashing algorithms (e.g. MD2, MD4, MD5 or SHA-1) can be vulnerable to collisions and other security weaknesses, and should not be used when reliable hashing of data is required
Impact	An attacker who obtains the hashed data may be able to recover the original values using brute-force, dictionary, rainbow table, or other cracking techniques. If the weak algorithm is used for password storage, successful cracking may result in account compromise and unauthorized access to application resources.
CVE/CWE	CWE-327 – Use of a Broken or Risky Cryptographic Algorithm
Severity	**Medium**
Recommendation	• Replace weak or deprecated hashing algorithms with modern, cryptographically secure algorithms. • For password storage, use dedicated password hashing algorithms such as Argon2id, bcrypt, or scrypt. • Use unique, randomly generated salts for each password. • Avoid using MD5, SHA-1, or unsalted SHA-256/SHA-512 for password storage. • Review existing stored hashes and migrate them to a stronger hashing scheme.
Reference	OWASP Password Storage Cheat Sheet MITRE CWE-327 – Use of a Broken or Risky Cryptographic Algorithm NIST SP 800-63B – Digital Identity Guidelines
New or Repeat observation	New
Status	New
References to evidences / Proof of Concept	

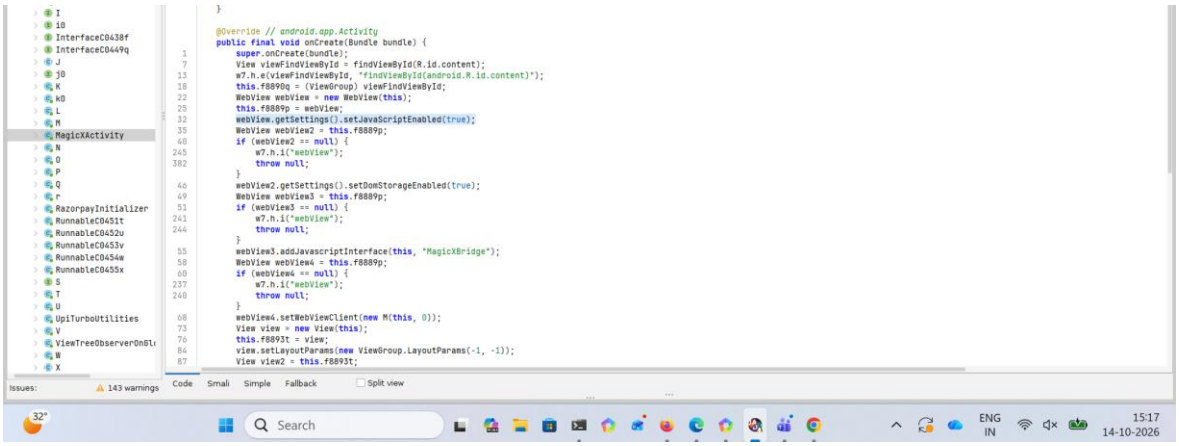


Closure Proof of Concept

NA

Vulnerability 10

Vulnerability Name	JS Enabled in a WebView
Affected Asset i.e. IP / URL / Application etc.	B/RunnableC0249d.java, com/razorpay/MagicXActivity.java
Detailed observation / Vulnerable point	The mobile application has enabled JavaScript in WebView. By default, JavaScript is disabled in WebView, if enabled it can bring various JS-related security issues, such as Cross-Site Scripting (XSS) attacks.
Impact	An attacker may exploit JavaScript execution to perform malicious actions within the WebView, potentially leading to cross-site scripting, unauthorized interaction with WebView content, data exposure, or exploitation of exposed WebView interfaces. The overall impact depends on the content loaded and the permissions or native interfaces exposed by the application.
CVE/CWE	CWE-79 – Improper Neutralization of Input During Web Page Generation (Cross-site Scripting) CWE-749 – Exposed Dangerous Method or Function
Severity	**Medium**
Recommendation	• Disable JavaScript execution in WebViews where it is not required for application functionality. • If JavaScript is necessary, restrict WebView content to trusted and controlled sources. • Implement strict URL allowlisting and prevent navigation to untrusted domains. • Avoid exposing sensitive native application interfaces to JavaScript through JavaScript bridges. • Apply appropriate WebView security configurations and keep the underlying platform and WebView components updated.
Reference	https://developer.android.com/privacy-and-security/security-tips#webview https://developer.android.com/reference/android/webkit/WebView.html https://developer.android.com/reference/android/webkit/WebSettings.html
New or Repeat observation	New
Status	New
References to evidences / Proof of Concept	



Closure Proof of Concept

NA

Disclaimer

Imperium Solutions conducted this Vulnerability Assessment & Penetration Testing of Android Application that existed as of 14th October 2026. Information security threats are continually changing, with new vulnerabilities discovered daily, and no application can ever be 100% secure no matter how much security testing is conducted.

This report cannot and does not protect against personal or business loss as the result of use of the applications or systems described. Imperium Solutions offers no warranties, representations or legal certifications concerning the applications or systems it tests. All software includes defects: nothing in this document is intended to represent or warrant that security testing was complete and without error, nor does this document represent or warrant that the application tested is suitable to task, free of other defects than reported, fully compliant with any industry standards, or fully compatible with any operating system, hardware, or other application.

Application team is supposed to mitigate vulnerabilities across the application. Any application maintenance, reconfigurations, or changes in general that have occurred following the assessment of an application, may alter the findings and recommendations.

10 Appendices

Glossary of terms:

Acronym	Full Form
CERT-In	Computer Emergency Response Team - India
OWASP	Open Worldwide Application Security Project
SANS	SysAdmin, Audit, Network, and Security Institute
PTES	Penetration Testing Execution Standard
CIS	Center for Internet Security
MITRE	MITRE Corporation (Originally: Massachusetts Institute of Technology Research and Engineering)
ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System

11 Appendices A: CERT-IN Compliance Status

During the assessment of this application, Imperium Solutions also conducted the audit as per the CERT-IN Circular No. 20(3)/2022, Compliance status of client mentioned below.

Control Description	Status of Effectiveness	Comments
Does the ICT (Information and Communication Technology) systems clocks are synced with National Informatics Centre (NIC) or National Physical Laboratory (NPL)?	Not in Scope	Not in Scope
Does the Cyber incident policy covers the process of reporting incident to the CERT-In? Incident reporting process should have below points included: • Incidents are required to be reported to CERT-In within 6 hours via email/phone mentioned in circular. • Include Reporting template mentioned in Annexure-I of the circular	Not in Scope	Not in Scope
Does the organization defined any employee as a point of contact for CERT-IN? Mention Name and email of PoC employee: Mention Name and email of PoC employee:	Not in Scope	Not in Scope
Is the logging enabled for all ICT systems? Are the logs stored securely? Is the rolling period for logs set for 180 days?	Not in Scope	Not in Scope
Are the logs stored in India?	Not in Scope	Not in Scope
The organization which provides services of Data Centers, VPS, VPN or Cloud Service maintain cancellation or withdrawal of the registration for minimum of 5 years? Following accurate details must be logged: • Validated names of subscribers/customers hiring the services. • Period of hire including dates. • IPs allotted to / being used by the members. • Email address and IP address and time stamp used at the time of • registration / on-boarding. • Purpose for hiring services.	Not in Scope	Not in Scope

Control Description	Status of Effectiveness	Comments
• Validated address and contact numbers. • Ownership pattern of the subscribers / customers hiring services.		
The organization which is virtual asset service provider, virtual asset exchange provider or custodian wallet providers maintain information obtained KYC and records of financial transactions for a period of 5 years?	Not in Scope	Not in Scope
The organization which is virtual asset service provider, virtual asset exchange provider or custodian wallet providers maintain transaction records such that individual transaction can be reconstructed along with information relating to the identification of the relevant parties including IP addresses along with timestamps and time zones, transaction ID, the public keys (or equivalent identifiers), addresses or accounts involved (or equivalent identifiers), the nature and date of the transaction, and the amount transferred.	Not in Scope	Not in Scope

The incidents can be reported to CERT-In via email (incident@cert-in.org.in), Phone (1800-11-4949) and Fax (1800-11-6969). The details regarding methods and formats of reporting cyber security incidents are also published on the website of CERT-In www.cert-in.org.in and will be updated from time to time.

For **Imperium Solutions**

Audit Conducted by: Mr. Uday Gupta

Audit Report Reviewed by: Mr. Chris

Audit Approved by: Mr. Jude Dcosta

Date:14.10.2026